Course: **GRC103 — Risk Assessment and Management Techniques**
Assessment: **Social Engineering & Phishing Campaign Simulation for GRC Professionals**
Student: Sisanda Lisa Masango
Registration Number: C11/26/CGRCE/17572
Date: 06 November 2026

Triage and Risk Assessment

Metric	Result	Calculated Rate	Risk Interpretation	Control Failure
Emails Opened	1/1	100%	Extreme susceptibility to engaging with untrusted external communications.	Ineffective security awareness training regarding message inspection.
Links Clicked	1/1	100%	Critical failure; target executed malicious link navigation without inspecting the URL domain.	Absence/ineffectiveness of automated URL rewriting, link sandboxing, or endpoint protection filters.
Credentials Submitted	1/1	100%	**Critical Risk.** Absolute compromise of single-factor authentication credentials.	Lack of Multi-Factor Authentication (MFA) enforcement on the target authentication portal.
Emails Reported	0/1	0%	Total reporting breakdown; Security Operations Center (SOC) receives zero early warning telemetry.	Missing single-click email reporting plugin or clear incident reporting workflow.

Executive Summary & Recommendations

1. Executive Summary

A controlled phishing simulation was conducted to evaluate organizational resilience against targeted social engineering tactics. The assessment utilized a simulated VPN credentials expiration prompt. The results demonstrate a **critical human risk posture**: 100% of targeted users opened the email, clicked the tracking payload link, and submitted active login credentials.

Furthermore, 0% of targets reported the suspicious message to internal security teams. Without technical controls like mandatory Multi-Factor Authentication (MFA), this vulnerability translates to immediate unauthorized network entry during an actual threat actor attack.

2. Key Findings & Metrics

- **Email Open Rate (100%):** Complete user engagement with themed social engineering lures.
- **Link Click-Through Rate (100%):** Total failure to inspect hyperlink targets prior to navigation.
- **Credential Submission Rate (100%): Highest Critical Severity.** Direct exposure of operational directory single-factor credentials.
- **Email Reporting Rate (0%):** Zero active reporting mechanisms utilized by end-users.

3. Risk Analysis

The current human firewall controls are failing to deter or contain credential harvesting attacks. In a production context, these results yield the following high-impact enterprise risks:

- **Initial Access & Lateral Movement:** Attackers leverage valid employee credentials to establish persistent access and bypass perimeter defenses.
- **Data Breach & Exposure:** Unauthorized access to corporate data stores, causing severe operational disruptions and potential legal liabilities under privacy laws (e.g., POPIA, GDPR).
- **Delayed Incident Response:** The 0% reporting rate ensures security operations remain unaware of active phishing campaigns during early attack stages.

4. Recommended Actions

- **Immediate Technical Control (Mandatory MFA):** Enforce Phishing-Resistant Multi-Factor Authentication (FIDO2 / Hardware Security Keys or Authenticator App push notifications) across all VPN and identity endpoints to render stolen passwords unusable.
- **One-Click Incident Telemetry:** Deploy an integrated "Report Phishing" button directly within user email clients to feed reporting metrics straight to the SOC.
- **Continuous Education:** Shift from annual static compliance training to continuous, real-world context simulations coupled with instant micro-learning modules for high-risk targets.
- **Policy Enforcement:** Update the Acceptable Use Policy (AUP) to formally detail user reporting obligations and incorporate phishing drill performance into annual GRC risk metrics.